

Unexpected security footguns in Go's parsers

Unexpected security footguns in Go's parsers - Author not stated, The Trail of Bits Blog.

- Published: 2025-06-18
- Original: <<https://blog.trailofbits.com/2025/06/17/unexpected-security-footguns-in-gos-parsers/>>
- Preserved from: <https://blog.trailofbits.com/2025/06/17/unexpected-security-footguns-in-gos-parsers/> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Page content

In Go applications, parsing untrusted data creates a dangerous attack surface that's routinely exploited in the wild. During our security assessments, we've repeatedly exploited unexpected behaviors in Go's JSON, XML, and YAML parsers to bypass authentication, circumvent authorization controls, and exfiltrate sensitive data from production systems.

These aren't theoretical issues—they've led to documented vulnerabilities like [CVE-2020-16250](#) (a Hashicorp Vault authentication bypass found by Google's Project Zero) and numerous high-impact findings in our client engagements.

This post contextualizes these unexpected parser behaviors through three attack scenarios that every security engineer and Go developer should understand:

- **(Un)Marshaling unexpected data:** How Go parsers can expose data that developers intended to be private
- **Parser differentials:** How discrepancies between parsers enable attackers to bypass security controls when multiple services parse the same input
- **Data format confusion:** How parsers process cross-format payloads with surprising and exploitable results

We'll demonstrate each attack scenario with real-world examples and conclude with concrete recommendations for configuring these parsers more securely, including strategies to compensate for security gaps in Go's standard library.

Below is a summary of the surprising behaviors we'll examine, with indicators showing their security status:

- **Green:** Secure by default

- **Orange:** Insecure by default but configurable
- **Red:** Insecure by default with no secure configuration options

		JSON		JSON v2		XML		YAML				json:"-,..."		YES (bad design)		YES (bad design)		YES (bad design)		YES (bad design)				json:"omitempty"		YES (expected)		YES (expected)		YES (expected)		YES (expected)				Duplicate keys		YES (last)		NO		YES (last)		NO				Case insensitivity		YES		NO		NO		NO				Unknown keys		YES (mitigable)		YES (mitigable)		YES		YES (mitigable)				Garbage leading data		NO		NO		YES		NO				Garbage trailing data		YES (with Decoder)		NO		YES		NO		
--	--	------	--	---------	--	-----	--	------	--	--	--	--------------	--	------------------	--	------------------	--	------------------	--	------------------	--	--	--	------------------	--	----------------	--	----------------	--	----------------	--	----------------	--	--	--	----------------	--	------------	--	----	--	------------	--	----	--	--	--	--------------------	--	-----	--	----	--	----	--	----	--	--	--	--------------	--	-----------------	--	-----------------	--	-----	--	-----------------	--	--	--	----------------------	--	----	--	----	--	-----	--	----	--	--	--	-----------------------	--	--------------------	--	----	--	-----	--	----	--	--

Parsing in Go

Let's examine how Go parses JSON, XML, and YAML. Go's standard library provides JSON and XML parsers but not a YAML parser, for which there are several third-party alternatives. For our analysis, we'll focus on:

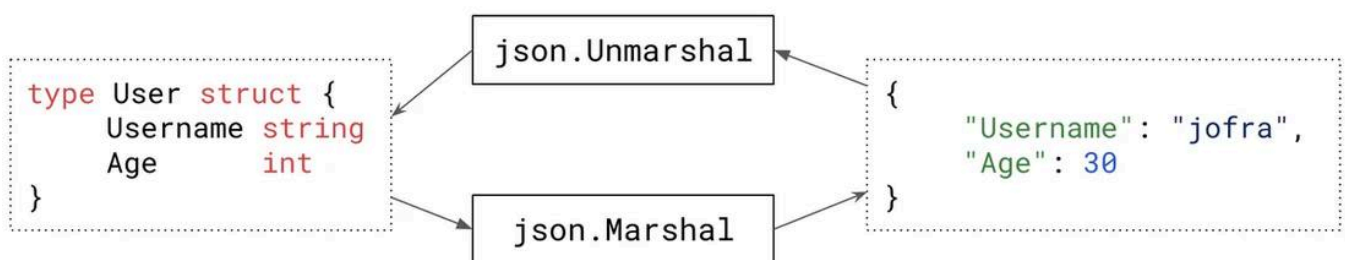
- [encoding/json](#) version go1.24.1
- [encoding/xml](#) version go1.24.1
- [yaml.v3](#) version 3.0.1 (the most popular third-party Go YAML library)

We'll use JSON in our following examples, but all three parsers have APIs equivalent to the ones we'll see.

At their core, these parsers provide two primary functions:

- `Marshal` (serialize): Converts Go structs into their respective format strings
- `Unmarshal` (deserialize): Converts format strings back into Go structs

```
import "encoding/json"
```



Go uses struct field tags to allow customization of how parsers should handle individual fields. These tags consist of:

- A **key name** for serialization/deserialization
- Optional **comma-separated directives** that modify behavior (e.g., the `omitempty` tag option tells the JSON serializer not to include the field in the JSON output string if it is empty)

```

type User struct {
    Username string `json:"username_json_key,omitempty"`
    Password string `json:"password"`
    IsAdmin bool `json:"is_admin"`
}

```

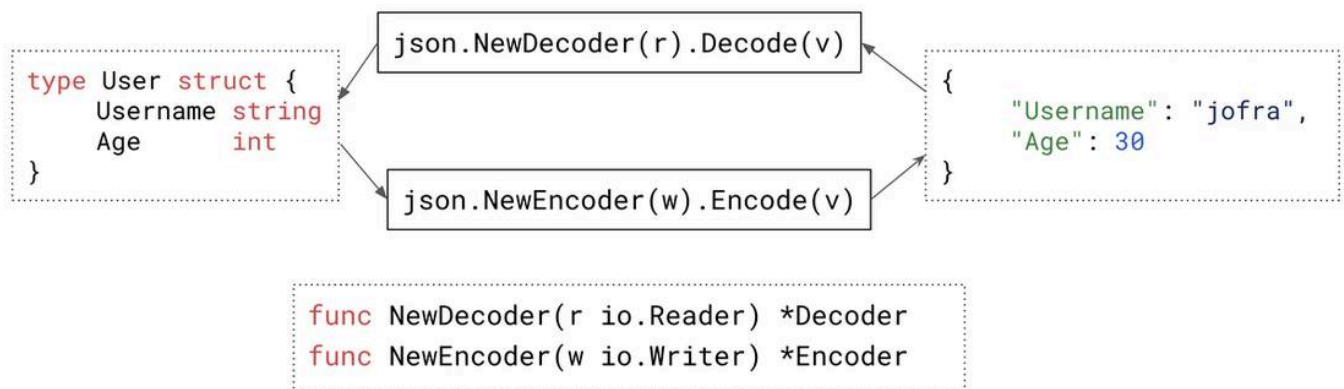
To unmarshal a JSON string into the `User` structure shown above, we must use the `username_json_key` key for the `Username` field, `password` for the `Password` field, and `is_admin` for the `IsAdmin` field.

```

u := User{}
_ = json.Unmarshal([]byte(`{
    "username_json_key": "jofra",
    "password": "qwerty123!",
    "is_admin": "false"
}`), &u)
fmt.Printf("Result: %#v\n", u)
// Result: User{Username:"jofra", Password:"qwerty123!", IsAdmin:false}

```

These parsers also offer stream-based alternatives that operate on `io.Reader` interfaces rather than `byte` slices. This API is ideal for parsing streaming data such as HTTP request bodies, making it a preferred choice in HTTP request handling.



Attack scenario 1: (Un)Marshaling unexpected data

Sometimes, you need to limit which fields of a structure can be marshaled or unmarshaled.

Let's consider a simple example in which a back-end server has an HTTP handler for creating users and another for retrieving that user after authentication.

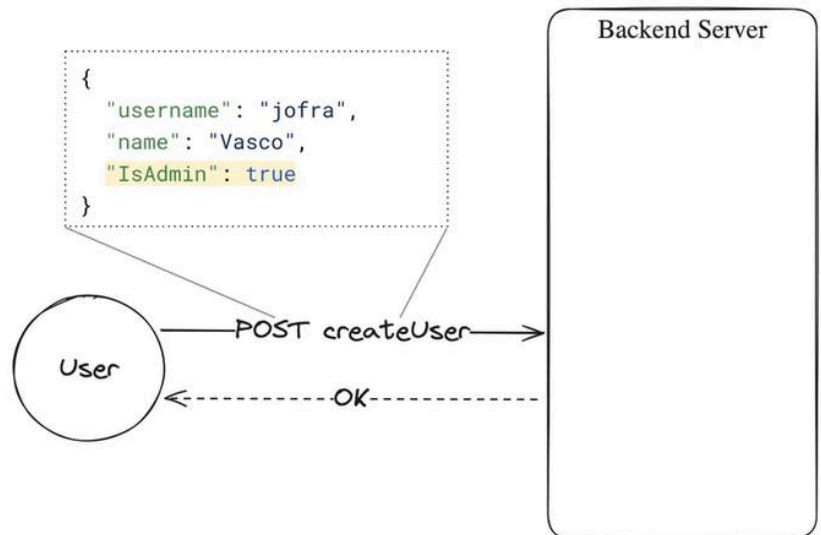
When creating a user, you may not want the user to be able to set the `IsAdmin` field (i.e., unmarshal that field from the user input).

```

type User struct {
    // Ok for users to set
    Username string
    FirstName string

    // NOT ok for users to set
    IsAdmin bool
}

```



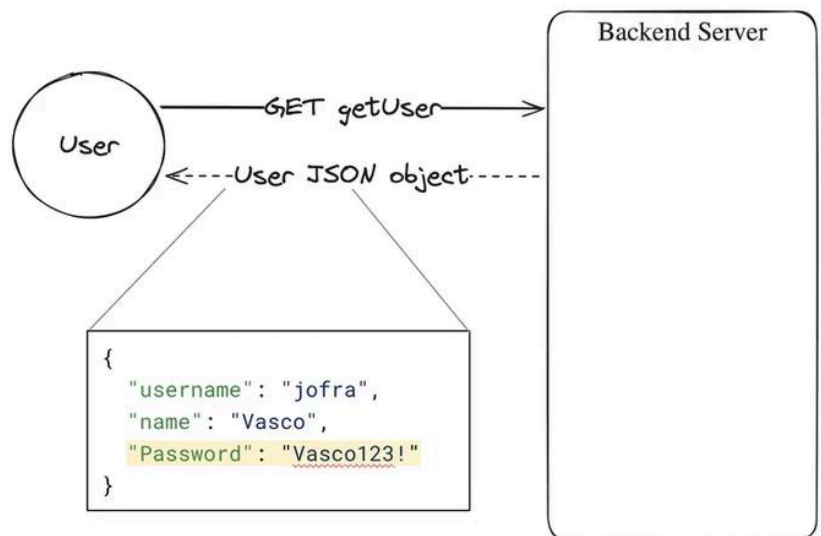
Similarly, when fetching the user, you may not want the user to return the user's Password or other secret values.

```

type User struct {
    // Ok for users to get
    Username string
    FirstName string

    // NOT ok for users to get
    Password string
}

```



How can we instruct the parsers not to marshal or unmarshal a field?

Fields without a tag

Let's first see what happens if you don't set a JSON tag.

```

type User struct {
    Username string
}

```

In this case, you can unmarshal the Username field with its name, as shown below.

```

_ = json.Unmarshal([]byte(`{"Username": "jofra"}`), &u)
// Result: User{Username:"jofra"}

```

This is well documented, and most Go devs are aware of it. Let's look at another example:

```
type User struct {
    Username string `json:"username,omitempty"`
    Password string `json:"password,omitempty"`
    IsAdmin bool
}
```

Is it evident that the `IsAdmin` field above would be unmarshaled? A less senior or distracted developer could assume it would not and introduce a security vulnerability.

If you'd like to scan your codebase for this pattern, where some but not all fields have a JSON, XML, or YAML tag, you can use the following Semgrep rule. This rule is not on our [collection of rules exposed on the Semgrep registry](#) because, depending on the codebase, it is likely to produce many false positives.

```
rules:
- id: unmarshaling-tag-in-only-some-fields
  message: >-
    Type $T1 has fields with json/yml/xml tags on some but not other fields. This field can still be (un)marshaled using
  languages: [go]
  severity: WARNING
  patterns:
  - pattern-inside: |
      type $T1 struct {
          ...
          $_ $_ `$_TAG`
          ...
      }
      # This regex attempts to remove some false positives such as structs declared inside structs
  - pattern-regex: >-
      ^[\t]+[A-Z]+[a-zA-Z0-9]*[\t]+[a-zA-Z0-9]+[\t]{\n\r}*$
  - metavariable-regex:
      metavariable: $_TAG
      regex: >-
          .*(json|yaml|xml):"[^,-]
```

Misusing the `-`` tag

To tell the parser not to (un)marshal a specific field, we must add the special `-`` JSON tag!

```
type User struct {
    Username string `json:"username,omitempty"`
    Password string `json:"password,omitempty"`
    IsAdmin bool `json:"- ,omitempty"`
}
```

Let's try it!

```
_ = json.Unmarshal([]byte(`{"-": true}`), &u)
// Result: main.User{Username:"", Password:"", IsAdmin:true}
```

Oh, whoops, we were still able to set the `IsAdmin` field. We copy-pasted the `,omitempty` part by mistake, which caused the parser to look for the `-` key in the provided JSON input. I searched for this pattern on the top 1,000 Go repositories by stars on GitHub and, among a few others, I found and reported these two results, which are now fixed:

- [Flit exposes the `ClientID` field on an OIDC configuration as the `-` field](#) (fixed in [#3658](#))
- [langchaingo exposes the `MaxTokens` field as the `-` field](#) (fixed in [#1163](#))

While this behavior is error prone with minimal benefits (having the ability to name a field `-`), it is [documented in the JSON package documentation](#):

As a special case, if the field tag is `"-"`, the field is always omitted. Note that a field with name `"-"` can still be generated using the tag `"-,"`.

The XML and YAML parsers operate similarly, with one key difference: the XML parser treats the `<->` tag as invalid. To resolve this, we must prefix the `-` symbol with an XML namespace, such as `<A:->`.

```
type User struct {
    IsAdmin bool `json:"- ,omitempty" xml:"A:- ,omitempty" yaml:"- ,omitempty"`
}
```

JSON

XML

YAML

```
{
  "-": true
}
```

```
<A:->true</A:->
```

```
-: true
```

XML namespace

Ok, ok, let's do it right this time.

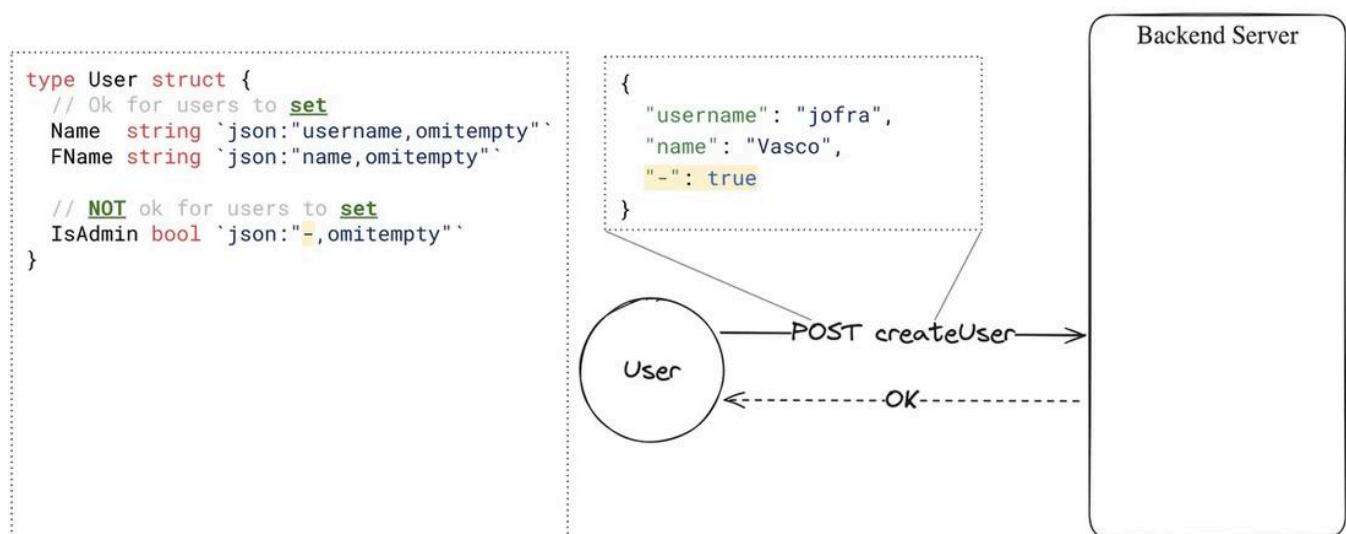
```

type User struct {
    Username string `json:"username,omitempty"`
    Password string `json:"password,omitempty"`
    IsAdmin bool `json:"-"`
}

```

Finally! Now, there is no way for the `IsAdmin` field to be unmarshaled.

But I hear you ask: How can these misconfigurations lead to security vulnerabilities? The most common way is, like in our example, using `-`,... as the JSON tag for a field such as `IsAdmin` –a field the user should not control. This is a hard bug to detect with unit tests because unless you have an explicit test that unmarshals an input with the `-` key and detects if any field was written to, you won't detect it. You need your IDE or an external tool to detect it.



We created a [public Semgrep rule](#) to help you find similar issues in your codebases. Try it with `semgrep -c r/trailofbits.go.unmarshal_tag_is_dash.unmarshal-tag-is-dash` !

Misusing omitempty

Another very simple misconfiguration we've found before was a developer mistakenly setting the field name to `omitempty`.

```

type User struct {
    Username string `json:"omitempty"`
}

u := User{}
_ = json.Unmarshal([]byte(`{"omitempty": "a_user"}`), &u)
// Result: User{Username:"a_user"}

```

If you set the JSON tag to `omitempty`, the parser will use `omitempty` as the field's name (as expected). Of course, some developers have tried to use this to set the `omitempty` option in the

field while keeping the default name. I searched the top 1,000 Go repositories for this pattern and found these results:

- Gitea exposes the `Args` field of the `TranslatableMessage` structure with the `omitempty` key (fixed in #33663)
- Kustomize exposes the `Replacements` field of the `plugin` structure with the `omitempty` key (fixed in #5877)
- Btcd exposes the `MaxFeeRate` field of the `TestMempoolAcceptCmd` structure with the `omitempty` key
- Evcc exposes the `Message` field of the `Measurements` structure with the `omitempty` key

In these cases, the developer often wanted to set the tag to `json:",omitempty"`, which would keep the default name, and add the `omitempty` tag option.

Contrary to the previous example, this one is unlikely to have a security impact and should be easy to detect with tests because any attempt to serialize or deserialize input with the expected field name will fail. However, as we can see, it still shows up even in popular open-source repositories.

We created a [public Semgrep rule](#) to help you find similar issues in your codebases. Try it with

```
semgrep -c r/trailofbits.go.unmarshal_tag_is_omitempty.unmarshal-tag-is-omitempty !
```

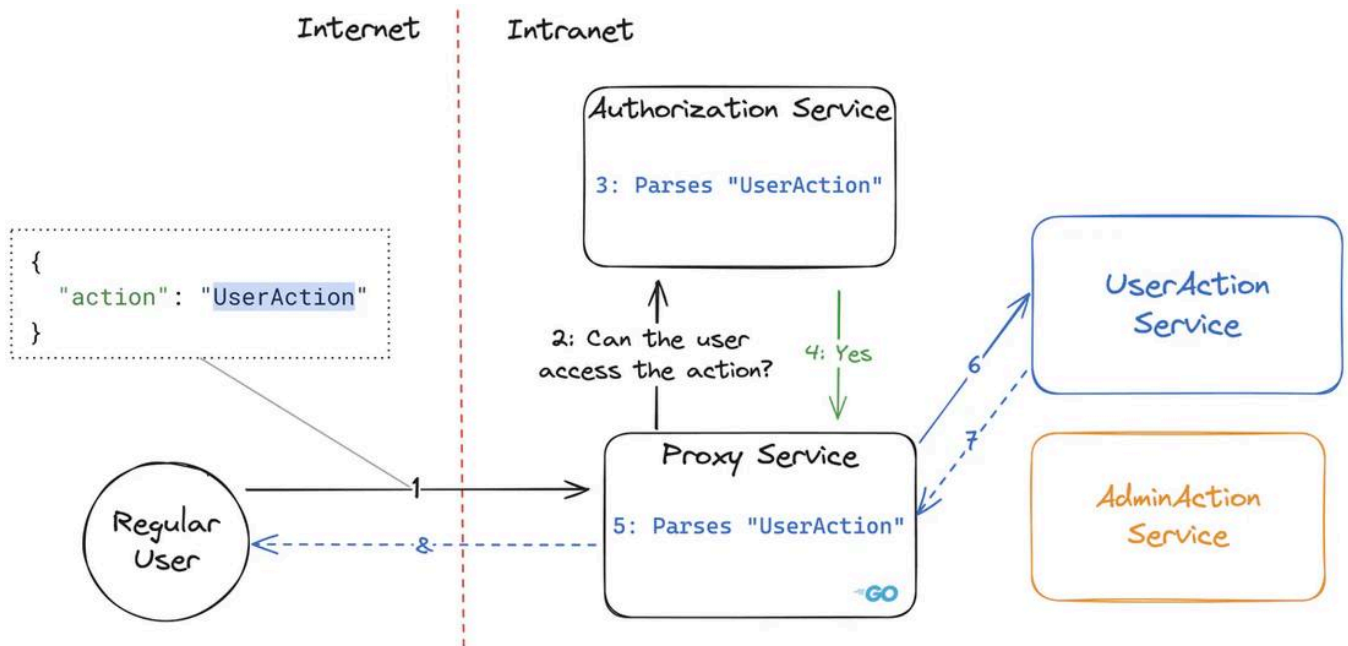
Attack scenario 2: Parser differentials

What can happen if you parse the same input with different JSON parsers and they disagree on the result? More specifically, which behaviors in Go parsers allow attackers to trigger these discrepancies “reliably”?

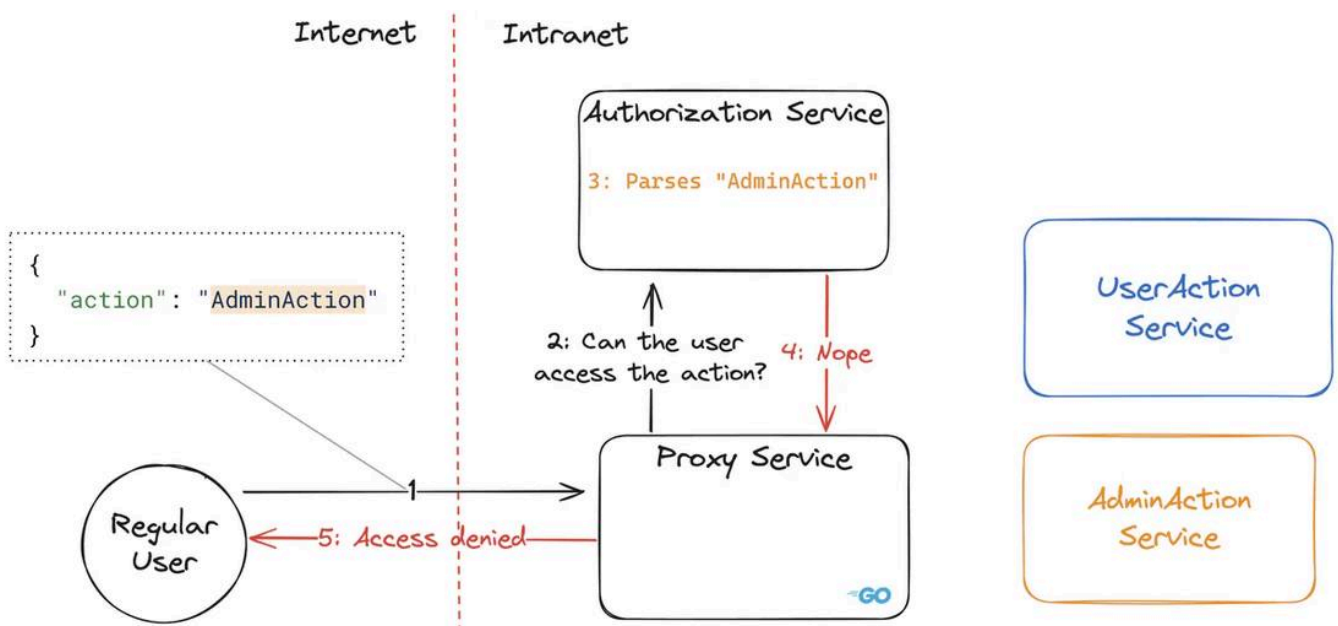
As an example, let’s use the following application using a microservice architecture with:

- A **Proxy Service** that receives all user requests
- An **Authorization Service** called by the Proxy Service to determine if the user has sufficient permission to complete their request
- Multiple **business logic services** called by the Proxy Service to perform the business logic

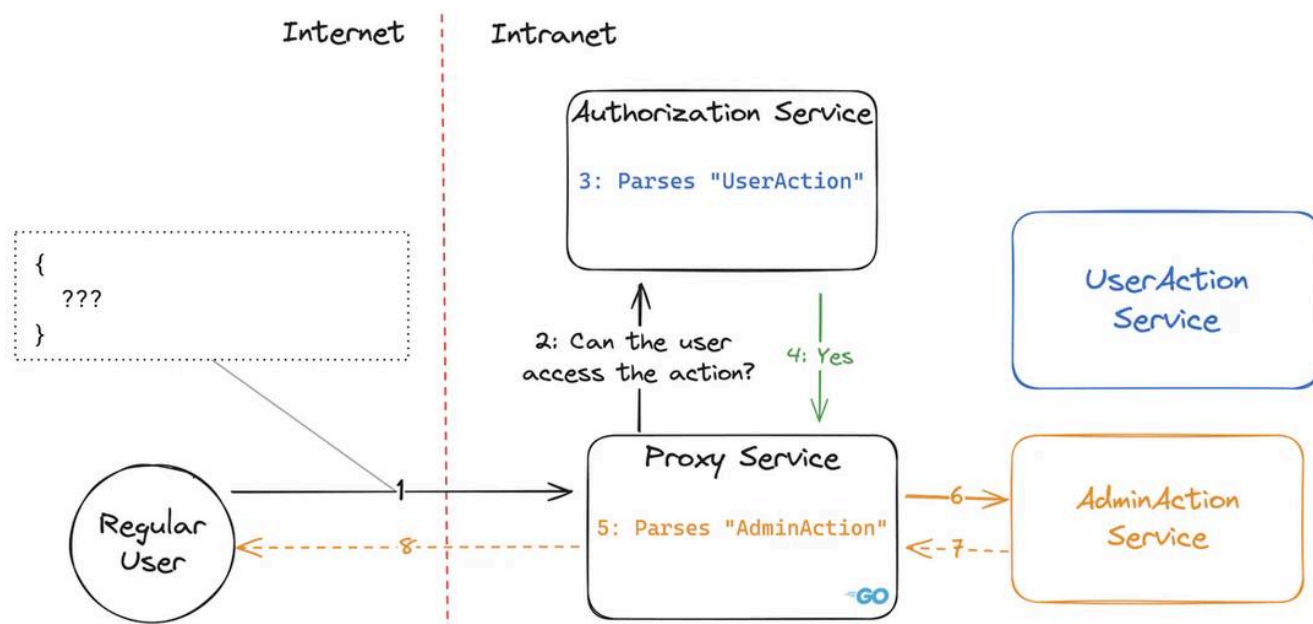
In this first flow, a regular, non-admin user attempts to perform a `UserAction`, an action they are **allowed** to perform.



In this second flow, the same regular user attempts to perform an **AdminAction**, an action they are **forbidden** to perform.



Finally, the following flow is because the services disagree on the action the user is trying to perform.



The Authorization Service, written in a different programming language or using a non-default Go parser, will parse `UserAction` and grant the user permission to perform the operation, while the Proxy Service, using Go's default parser, will parse `AdminAction` and proxy it to the incorrect service. The remaining question is: Which payloads can we use to achieve this behavior?

This is a common architecture we've seen multiple times during our audits, and against which we've found authentication bypasses because of the problems we'll describe below. Other examples exist, but most follow the same pattern: the component that does security checks and the component that performs the actions differ in their view of the input data. Here are some of those examples in a variety of scenarios:

- [CVE-2017-12635: Authorization bypass in Apache CouchDB caused by JSON parser differentials](#) (very similar to our example above)
- [MacOS sandbox escape caused by XML parser differentials \(2020\)](#)
- [0-click Zoom RCE caused by XML parser differentials in XMPP \(2022\)](#)
- [GitLab SAML auth bypass caused by XML parser differentials \(2025\)](#)

Duplicate fields

The first differential attack vector we'll explore is duplicate keys. What happens when your JSON input has the same key twice? It depends on the parser!

In Go, the JSON parser will always **take the last one**. There is no way to prevent this behavior.

```

_ = json.Unmarshal([]byte(`{
  "action": "Action1",
  "action": "Action2"
}`, &a)
// Result: ActionRequest{Action:"Action2"}

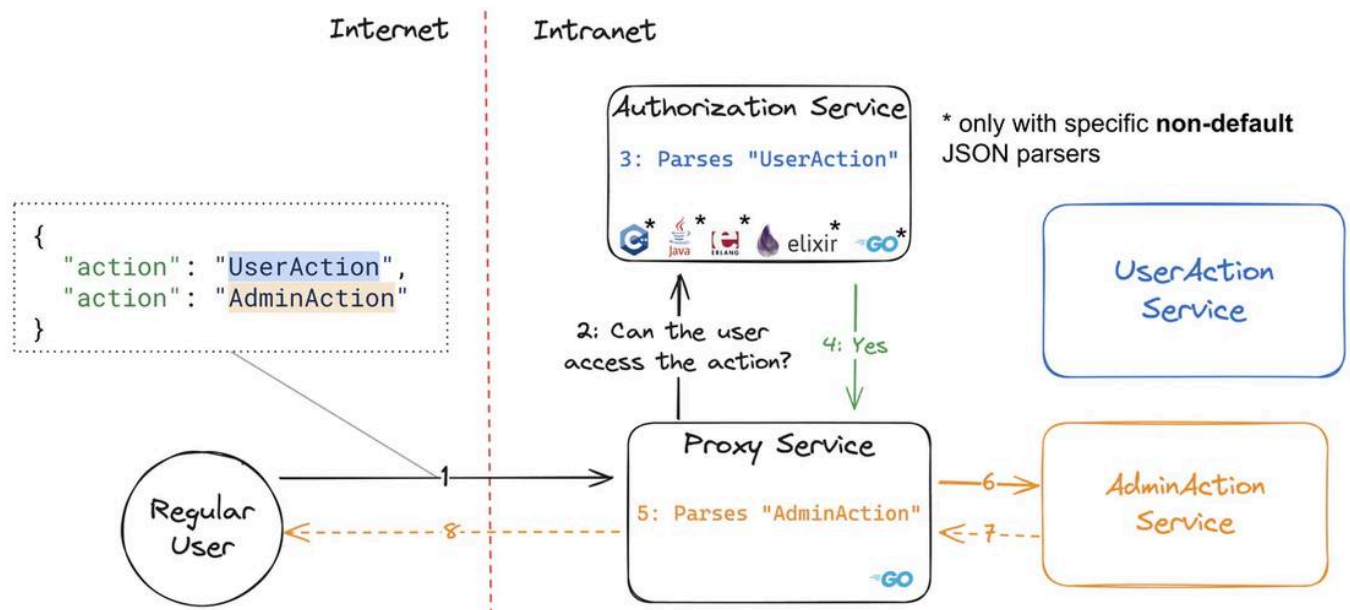
```

This is the default behavior of most parsers. However, as shown in the [JSON interoperability vulnerabilities](#) blog post from Bishop Fox, seven out of the 49 parsers tested take the first key:

- Go: jsonparser and gojay
- C++: rapidjson
- Java: json-iterator
- Elixir: Jason and Poison
- Erlang: jsone

None of these are the most common JSON parsers in their corresponding languages, even though some are common alternatives.

So, if our Proxy Service uses the Go JSON parser and the Authorization Service uses one of these parsers, we get our discrepancy, as shown in the figure below.



The XML parser has the same behavior, while the YAML parser returns an error on duplicate fields—the secure default we think all of these parsers should implement.

```
type ActionRequest struct {
  Action string `json:"action" xml:"action" yaml:"action"`
}
```

JSON

XML

YAML

```
{
  "action": "Action_1",
  "action": "Action_2"
}
```

Action_2

```
<action>Action_1</action>
<action>Action_2</action>
```

Action_2

```
action: Action_1
action: Action_2
```

&yaml.TypeError{mapping key
\"action\" already defined}

While not ideal, at least this behavior is consistent with the most commonly used JSON and XML parsers. Let's now take a look at a much worse behavior that will almost always get you a discrepancy between Go's default parser and any other parser.

Case insensitive key matching

Go's JSON parser parses field names case-insensitively. Whether you write `action`, `ACTION`, or `aCtIoN`, the parser treats them as identical!

```
_ = json.Unmarshal([]byte(`{
  "aCtIoN": "Action2"
}`, &a)
// Result: ActionRequest{Action:"Action2"}
```

This is [documented](#) but is very unintuitive, there's no way to disable it, and almost no other parser has this behavior.

To make this worse, as we saw above, you can have duplicate fields, and the latter one is still chosen, eVeN wHeN tHe cAsInG dOeS nOt mAtCh.

```
_ = json.Unmarshal([]byte(`{
  "action": "Action1",
  "aCtIoN": "Action2"
}`, &a)
// Result: ActionRequest{Action:"Action2"}
```

This is against the documentation, which says:

“To unmarshal JSON into a struct, Unmarshal matches incoming object keys to the keys used by Marshal (either the struct field name or its tag), **preferring an exact match but also accepting a case-insensitive match.**”

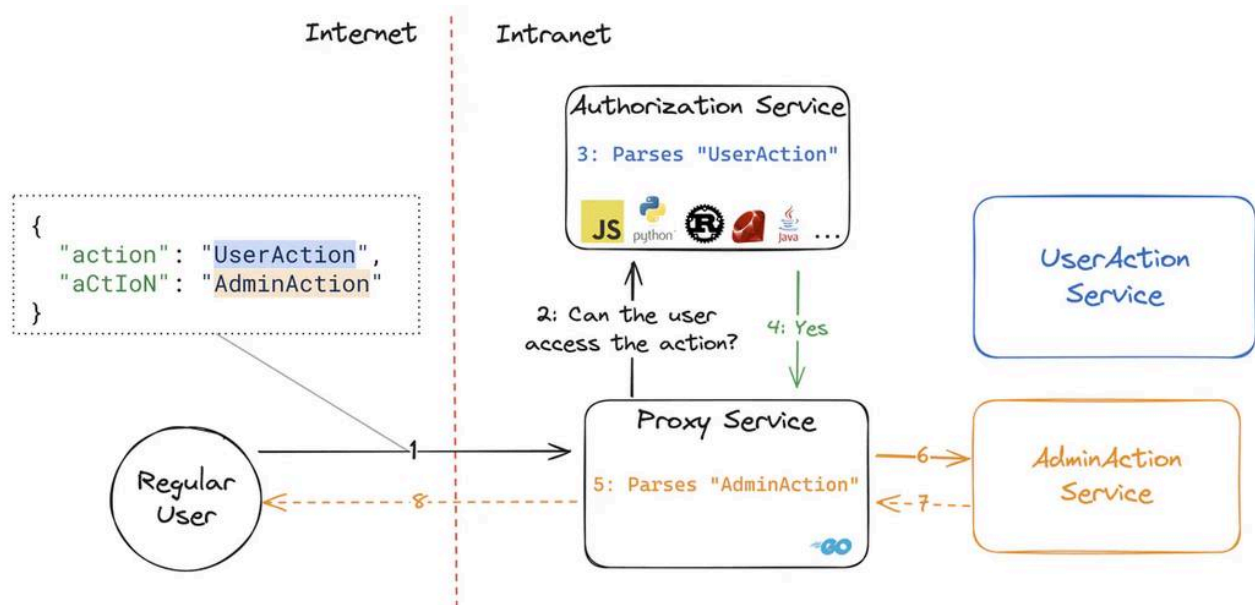
You can even use Unicode characters! In the example below, we're using `ſ` (the unicode character named Latin small letter long s) as an `s`, and `℔` (the unicode character for the Kelvin sign) as a `k`. From our testing of the [JSON library code](#) that does the comparison, only these two unicode characters match ASCII characters.

```

type ActionRequest struct {
    Action string `json:"aktions"`
}
a := ActionRequest{}
_ = json.Unmarshal([]byte(`
{
    "aktions": "Action1",
    "aKtionf": "Action2"
}
`), &a)
fmt.Printf("Result: %#v\n", a)
// Result: main.ActionRequest{Action:"Action2"}

```

Applying it to our running attack scenario, this is how the attack would look like:



In our opinion, this is the most critical pitfall of Go's JSON parser because it differs from the default parsers for JavaScript, Python, Rust, Ruby, Java, and all other parsers we tested. This has led to many high-impact security vulnerabilities, including ones we've found during our audits.

As a final blow, there's no way to disable this behavior, even though people have complained about this [behavior leading to security vulnerabilities](#) since at least 2016.

This only affects the JSON parser. The XML and YAML parsers use exact matches.

```
type ActionRequest struct {
    Action string `json:"action" xml:"action" yaml:"action"`
}
```

JSON

```
{
  "action": "Action_1",
  "aCtIoN": "Action_2"
}
```

Action_2

XML

```
<action>Action_1</action>
<aCtIoN>Action_2</aCtIoN>
```

Action_1

YAML

```
action: Action_1
aCtIoN: Action_2
```

Action_1

If you are interested in other kinds of JSON parsing differentials between many parsers, we recommend these two blog posts:

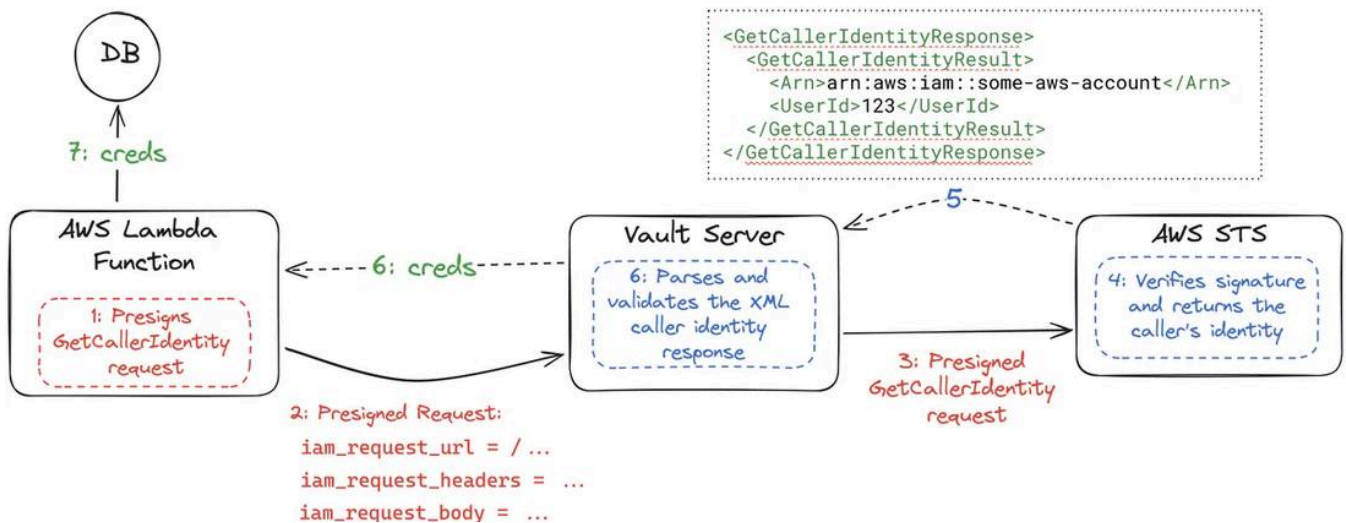
- [Parsing JSON is a Minefield](#) by Nicolas Seriot
- [JSON Interoperability Vulnerabilities](#) by Bishop Fox

Attack scenario 3: Data format confusion

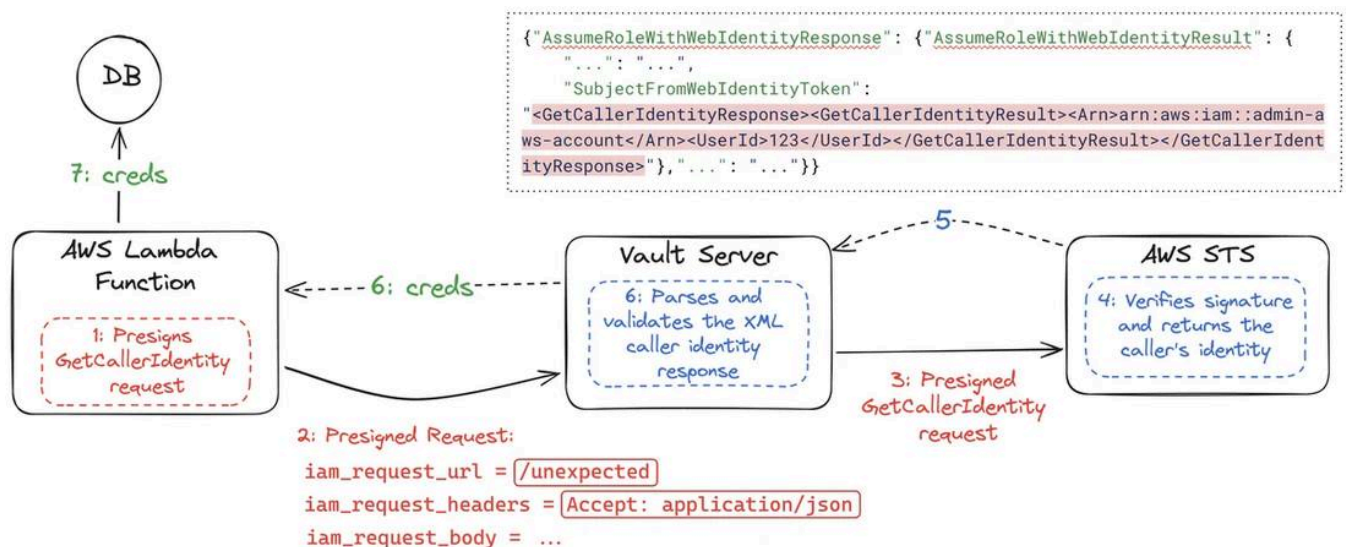
For the final attack scenario, let's see what happens if you parse a JSON file with the XML parser or use any other format with the incorrect parser.

As an example, let's use [CVE-2020-16250](#), an Hashicorp Vault bypass in its AWS IAM authentication method. This bug was found by Google's Project Zero team, and a detailed analysis can be found in their "[Enter the Vault: Authentication Issues in HashiCorp Vault](#)" blog post if you are interested. We won't go through all the details in this post, but in summary, this is how the normal Hashicorp Vault AWS IAM authentication flow works:

- An AWS resource (e.g., an AWS Lambda function) presigns a [GetCallerIdentity](#) request.
- The AWS resource sends it to the Vault Server.
- The Vault Server builds that requests and sends it to the AWS Security Token Service (STS).
- AWS STS verifies the signature.
- On success, AWS STS returns the associated role's identity in an XML document.
- The Vault Server parses the XML, extracts the identity, and, if that AWS role should have access to the requested secrets, it returns them.
- The AWS resource can now use the secret to, for example, authenticate against a database.



What Google's Project Zero team found was that an attacker could control too much in step 2, including controlling all headers of the request that Vault builds in step 3. In particular, by setting the `Accept` header to `application/json`, AWS STS would now return a JSON document in step 5 instead of the expected XML document. As a result, the Vault Server would parse a JSON document with Go's XML parser. Because the XML parser is very lenient and parses anything that looks like XML in between lots of other "garbage" data, this was sufficient for a full authentication bypass when combined with partial control of the JSON response.



Let's look at three different behaviors that make parsing files with the wrong Go parser possible and build a polyglot that can be parsed with Go's JSON, XML, and YAML parsers and return a different result for each.

Unknown keys

By default, the JSON, XML, and YAML parsers don't prevent unknown fields—properties in the incoming data that don't match any fields in the target struct.

```
type ActionRequest struct {
    Action string `json:"action" xml:"action" yaml:"action"`
}
```

JSON

```
{
  "action": "test",
  "rand_key": "asd"
}
```

```
main.ActionRequest{
  Action: "test"
}
```

XML

```
<action>test</action>
<rand_key>asd</rand_key>
```

```
main.ActionRequest{
  Action: "test"
}
```

YAML

```
action: test
rand_key: asd
```

```
main.ActionRequest{
  Action: "test"
}
```

Leading garbage data

Of the three parsers, only the XML parser accepts leading garbage data.

```
type ActionRequest struct {
    Action string `json:"action" xml:"action" yaml:"action"`
}
```

JSON

```
garbage !#{ }[] data{
  "action": "test"
}
```

JSON decode error: invalid character 'g' looking for beginning of value

XML

```
garbage !#{ }[] data<xml>
  <action>test</action>
</xml>
```

```
main.ActionRequest{
  Action: "test"
}
```

YAML

```
garbage !#{ }[] data
action: test
```

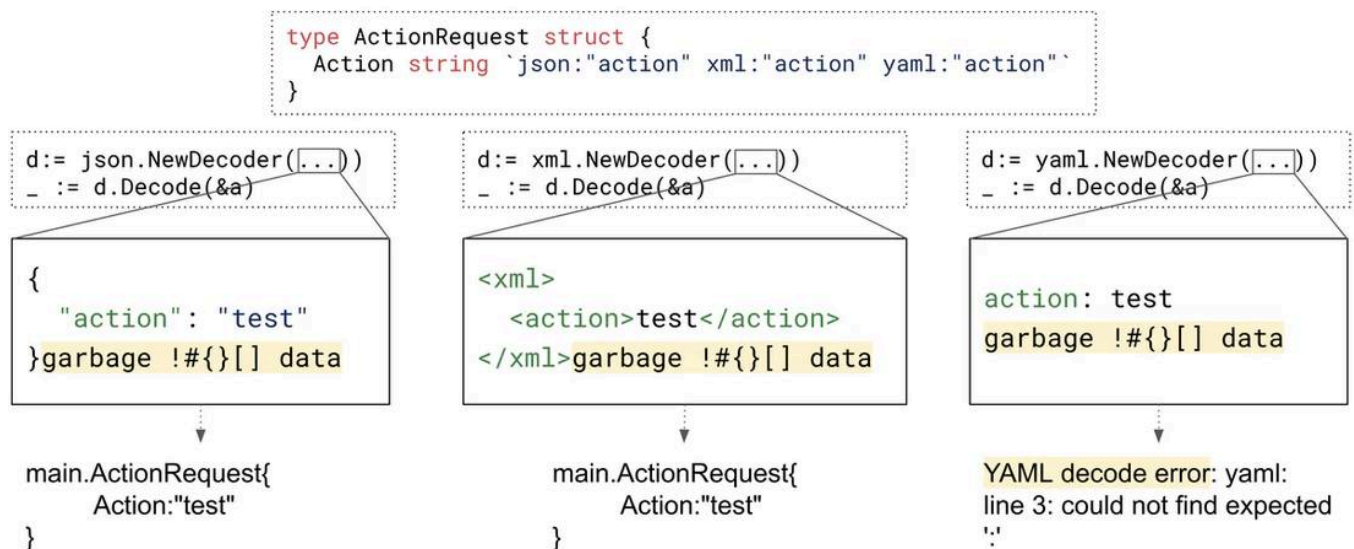
YAML decode error: yaml: line 3: mapping values are not allowed in this context

Trailing garbage data

Again, only the XML parser accepts arbitrary trailing garbage data.



The exception is using the parsers' Decoder API with streaming data, in which case the JSON parser accepts garbage trailing data. This an [open issue](#) for which a fix is not planned.



Constructing a polyglot

How can we combine all the behaviors we've seen so far that build a polyglot that:

- Can be parsed by Go's JSON, XML, and YAML parsers
- Returns a different result for each

A very useful piece of information is that JSON is a subset of YAML:

Every JSON file is also a valid YAML file

With this in mind, we can build the following polyglot:

```
type ActionRequest struct {  
    Action string `json:"action" xml:"action" yaml:"action"`  
}
```

```
{  
  "action": "Action_1",  
  "aCtIoN": "Action_2",  
  "random": "<xml><action>Action_3</action></xml>"  
}
```

JSON

Action_2

XML

Action_3

YAML

Action_1

The JSON parser can parse the polyglot because the input is valid JSON, it ignores unknown keys, and it allows duplicate keys. It takes the `Action_2` value because its field matching is case-insensitive and it takes the value of the last match.

The YAML parser can parse the polyglot because the input is valid JSON (and every JSON file is also a valid YAML file), and it ignores unknown keys. It takes the `Action_1` value because, contrary to the JSON parser, it does exact field name matches.

Finally, the XML parser can parse the polyglot because it ignores all surrounding data and just looks for XML-looking data, which, in this polyglot, we hid in a JSON value. As a result, it takes `Action_3`.

The polyglot we've constructed is a powerful starting payload when exploiting these data format confusion attacks similar to the HashiCorp Vault bypass we explored above (CVE-2020-16250).

Mitigations

How can we minimize these risks and make JSON parsing more strict? We'd like to:

- Prevent parsing of **unknown keys** in JSON, XML, and YAML
- Prevent parsing of **duplicate keys** in JSON and XML
- Prevent **case insensitive key matches** in JSON (this one is especially important!)
- Prevent **leading garbage data** in XML
- Prevent **trailing garbage data** in JSON and XML

Unfortunately, JSON only offers one option to make its parsing stricter: `DisallowUnknownFields`. As the name implies, this option disallows unknown fields in the input JSON. YAML supports the same functionality with the `KnownFields(true)` function, and while there was a [proposal](#) to implement the same for XML, it was rejected.

To prevent the remaining insecure defaults, we must create a custom "hacky" solution. The next code block shows the `strictJSONParse` function, an attempt to make JSON parsing stricter, which

has several limitations:

- **Bad performance:** It requires parsing JSON input twice, making it significantly slower.
- **Incomplete detection:** Some edge cases remain undetected, as detailed in the function comments.
- **Poor adoption potential:** Since these security measures aren't built into libraries as secure defaults or configurable options, widespread adoption is unlikely.

Still, if you detect a vulnerability in your codebase, perhaps this imperfect solution can help you plug a hole while you find a more permanent solution.

```

// DetectCaseInsensitiveKeyCollisions checks if the JSON data contains keys
// that differ only by letter case. This helps prevent subtle bugs where two
// different key spellings might refer to the same data.
func DetectCaseInsensitiveKeyCollisions(data []byte) error {
    // Create a map to hold the decoded JSON data and attempt to parse the JSON
    // data. This keeps keys with different letter casing.
    var res map[string]interface{}
    if err := json.NewDecoder(bytes.NewReader(data)).Decode(&res); err != nil {
        return err
    }

    seenKeys := make([]string, 0, len(res))

    // Iterate through all keys in the parsed JSON and detect duplicates
    for newKey := range res {
        for _, existingKey := range seenKeys {
            if strings.EqualFold(existingKey, newKey) {
                // Return an error when a case-insensitive duplicate is found
                return fmt.Errorf("case-insensitive duplicate keys detected:
                    %q and %q", existingKey, newKey)
            }
        }
        seenKeys = append(seenKeys, newKey)
    }
    return nil
}

// Provides a stricter JSON parsing with additional validation:
// 1. Rejects unknown fields not in the target struct
// 2. Detects case-insensitive key collisions
// 3. Ensures complete parsing with no trailing content
// strictJSONParse does not:
// - Ensure that there are no duplicate keys with the same casing
// - Ensure that the casing in the input matches the expected casing
//   in the target struct
func strictJSONParse(jsonData []byte, target interface{}) error {
    decoder := json.NewDecoder(bytes.NewReader(jsonData))

    // 1. Disallow unknown fields
    decoder.DisallowUnknownFields()

    // 2. Disallow duplicate keys with different casing
    err := DetectCaseInsensitiveKeyCollisions(jsonData)
    if err != nil {

```

```

    return fmt.Errorf("strictJSONParse: %w", err)
}

// Decode the JSON into the provided struct
err = decoder.Decode(target)
if err != nil {
    return fmt.Errorf("strictJSONParse: %w", err)
}

// 3. Ensure there's no trailing data after the JSON object
token, err := decoder.Token()
if err != io.EOF {
    return fmt.Errorf("strictJSONParse: unexpected trailing data after
        JSON: token: %v, err: %v", token, err)
}

return nil
}

```

JSONv2

To be widely adopted and solve the problem at a large scale, this functionality needs to be implemented at the library level and enabled by default. This is where [JSON v2](#) comes in. It is currently only a proposal, but a lot of work has gone into it already, and it will hopefully be released soon. It improves on JSON v1 in many ways, including:

- Disallowing duplicate names: “(...) in v2 a JSON object with duplicate names results in an error. The `jsontext.AllowDuplicateNames` option controls this behavior difference.”
- Doing case-sensitive matching: “(...) v2 matches fields using an exact, case-sensitive match. The `MatchCaseInsensitiveNames` and `jsonv1.MatchCaseSensitiveDelimiter` options control this behavior difference.”
- It includes a `RejectUnknownMembers` option, even though it is not enable by default (equivalent to `DisallowUnknownFields`).
- It includes a `UnmarshalRead` function to process data from an `io.Reader`, verifying that an EOF is found, disallowing trailing garbage data.

While this proposal addresses many of the issues discussed in this blog post, these challenges will persist within the Go ecosystem as widespread adoption takes time. The proposal needs formal acceptance, after which developers must integrate it into all existing JSON-parsing Go code. Until then, these vulnerabilities will continue to pose risks.

Key takeaways for developers

Implement strict parsing by default. Use `DisallowUnknownFields` for JSON, `KnownFields(true)` for YAML. Unfortunately, this is all you can do directly with the Go parser APIs.

-

Maintain consistency across boundaries. When input is processed in multiple services, ensure consistent parsing behavior by always using the same parser or implement additional validation layers, such as the `strictJSONParse` function shown above.

-

Watch for JSON v2. Keep an eye on the development of Go's [JSON v2](#) library, which addresses many of these issues with safer defaults for JSON.

-

Leverage static analysis. Use the Semgrep rules we've provided to detect a few vulnerable patterns in your codebase, particularly the misuse of the `-` tag and `omitempty` fields. Try them with `semgrep -c r/trailofbits.go.unmarshal_tag_is_dash.unmarshal-tag-is-dash` and `semgrep -c r/trailofbits.go.unmarshal_tag_is_omitempty.unmarshal-tag-is-omitempty !`

While we've provided mitigations and detection strategies, the long-term solution requires fundamental changes to how these parsers operate. Until parser libraries adopt secure defaults, developers must remain vigilant.